ShopFlow Order Management Service

Software Requirements Specification, version 1.2

Fictional system. This document was written as test material for the TechSpec-MultiAgent-RAG thesis project.

1. Introduction

1.1 Purpose

This document specifies the requirements of the ShopFlow Order Management Service, the backend that lets customers of an online shop register, search the product catalog, manage a shopping cart, place and pay for orders, and track them. It is intended for the developers, testers and operators of the service.

1.2 Scope

The service covers customer accounts, the product catalog, the shopping cart, orders, payments and sales reporting. Warehouse management, shipping label printing and the mobile applications are out of scope and are specified in separate documents.

1.3 Definitions

Customer: a registered user who buys products. **Administrator:** an employee with the ADMIN role. **Order status:** one of PENDING_PAYMENT, PAID, SHIPPED, DELIVERED or CANCELLED. **Payment provider:** the external company that processes card payments and notifies ShopFlow through webhooks.

2. System Overview

ShopFlow is a REST API behind an API gateway. The Order Service stores accounts, carts and orders in a PostgreSQL database. The Inventory Service keeps the stock of every product and handles reservations. A Redis cache stores product pages and rate limit counters. Card payments are processed by an external payment provider, which reports the result of every payment through a signed webhook. Emails are sent through an external email delivery service.

All endpoints except registration, login, product search and the payment webhook require a valid access token in the Authorization header.

3. Functional Requirements

3.1 Accounts and Authentication

FR-01 Customer registration. The system shall allow a customer to register with an email address and a password of at least 12 characters. The email address shall be unique across all accounts.

FR-02 Login. The system shall authenticate customers with email and password and return a JWT access token valid for 15 minutes and a refresh token valid for 7 days.

FR-03 Account lockout. After 5 consecutive failed login attempts, the system shall lock the account for 15 minutes and notify the customer by email.

3.2 Catalog and Cart

FR-04 Product search. The system shall allow customers to search products by keyword and filter them by category. Results shall be paginated with 20 items per page by default and at most 100 items per page.

FR-05 Shopping cart. The system shall allow a customer to add a product to the cart with a quantity between 1 and 20 units. Adding a quantity above the available stock shall be rejected with HTTP 409.

3.3 Orders and Payments

FR-06 Stock reservation. When an order is created, the system shall reserve the ordered stock for 15 minutes until the payment is confirmed. Reservations that are not paid within 15 minutes shall be released automatically.

FR-07 Order creation. The system shall create an order from the contents of the cart and return the order with the status PENDING_PAYMENT.

FR-08 Payment confirmation. When the payment provider sends a payment_succeeded webhook, the system shall change the order status to PAID and send a confirmation email to the customer within 60 seconds.

FR-09 Order cancellation. A customer shall be able to cancel an order only while its status is PENDING_PAYMENT or PAID. Cancelling a PAID order shall trigger a full refund through the payment provider.

FR-10 Order history. The system shall show a customer all of their orders, sorted from newest to oldest.

3.4 Administration

FR-11 Sales report. Administrators shall be able to export a sales report for a selected date range as a CSV file.

FR-12 Admin usability. The admin panel should be user-friendly and easy to use.

FR-13 Product page speed. Product pages should load fast.

4. API Specification

All endpoints accept and return JSON unless stated otherwise. Paths are relative to https://api.shopflow.example.

POST /api/v1/auth/register. Parameters: email, password. Registers a new customer. Returns 201 Created, or 409 Conflict if the email is already used.

POST /api/v1/auth/login. Parameters: email, password. Returns an access token and a refresh token. Returns 401 Unauthorized for wrong credentials and 423 Locked for a locked account.

POST /api/v1/auth/refresh. Parameters: refresh_token. Returns a new access token.

GET /api/v1/products. Parameters: q, category, page, size. Searches products. size must be between 1 and 100.

GET /api/v1/products/{product_id}. Parameters: product_id. Returns one product with its current stock. Returns 404 Not Found if it does not exist.

POST /api/v1/cart/items. Parameters: product_id, quantity. Adds a product to the cart of the authenticated customer.

DELETE /api/v1/cart/items/{item_id}. Parameters: item_id. Removes an item from the cart.

POST /api/v1/orders. Parameters: shipping_address_id, payment_method. Creates an order from the cart and reserves the stock.

GET /api/v1/orders/{order_id}. Parameters: order_id. Returns an order of the authenticated customer.

POST /api/v1/orders/{order_id}/cancel. Parameters: order_id. Cancels an order. Returns 409 Conflict if the order is already SHIPPED.

POST /api/v1/payments/webhook. Parameters: event_type, order_id, signature. Receives payment events from the payment provider. Requests with an invalid signature are rejected with 401.

GET /api/v1/admin/reports/sales. Parameters: from, to. Returns the sales report as CSV. Requires the ADMIN role, otherwise 403 Forbidden.

5. Non-Functional Requirements

5.1 Performance and Availability

NFR-01 Performance. 95% of API requests shall complete within 300 ms under a load of 500 requests per second.

NFR-02 Availability. The service shall be available 99.9% of the time per calendar month, excluding planned maintenance announced at least 48 hours in advance.

5.2 Security and Privacy

NFR-03 Transport and password security. All traffic shall use TLS 1.2 or higher. Passwords shall be stored only as bcrypt hashes with a cost factor of 12.

NFR-04 Rate limiting. Each authenticated client shall be limited to 100 requests per minute. Requests above the limit shall receive HTTP 429 with a Retry-After header.

NFR-06 Data privacy. Personal data of a customer shall be deleted within 30 days after the customer requests deletion of the account, in line with the GDPR.

5.3 Operations

NFR-05 Backup and recovery. The database shall be backed up every 15 minutes (RPO of 15 minutes), and the service shall be restored within 1 hour after a failure (RTO of 1 hour).

NFR-08 Logging. Every API request shall be logged with a unique request ID. Logs shall be kept for 90 days and shall never contain passwords or payment card numbers.

NFR-09 Scalability. The system should scale to handle a large number of users.

5.4 Usability

NFR-07 Accessibility. The customer storefront shall conform to WCAG 2.1 level AA.

6. Business Rules

An order moves from PENDING_PAYMENT to PAID, then to SHIPPED and DELIVERED. An order can be CANCELLED only from PENDING_PAYMENT or PAID. Prices include VAT at the rate of the shipping country. A customer can have at most one open cart at a time.

7. Error Handling

Every error response has the JSON body {"error": {"code": "...", "message": "..."}}. The service uses 400 Bad Request for invalid input, 401 Unauthorized for a missing or invalid token, 403 Forbidden for a missing role, 404 Not Found for unknown resources, 409 Conflict for state conflicts, 423 Locked for locked accounts, 429 Too Many Requests when the rate limit is exceeded and 500 Internal Server Error for unexpected failures. Error messages shall not reveal internal details such as stack traces or SQL statements.